

NeoGRC

Test Tour

A guided pass through every subsystem, using the demo dataset

Roughly 45 minutes end to end · run on a scratch site, never production

Application	neogrc
Version	0.2.0
Demo dataset	neogrc.demo.dataset
Demo entity	Wadi Marine Logistics (fictional)
Document date	12 August 2026
Audience	QA, implementation consultants, reviewers

0 Setup

Every subsystem below is exercised against a single demo dataset. Run it on a scratch site.

```
bench --site testsite install-app neogrc  
bench --site testsite migrate  
bench --site testsite execute neogrc.demo.dataset.install
```

The installer prints a JSON summary. Expect 3 users, 3 policies, 4 vendors, 4 risks, 3 exceptions, 12 metrics, and 9 findings across two batches. Every record it creates is tagged neogrc-demo.

```
bench --site testsite execute neogrc.demo.dataset.purge
```

The demo programme is deliberately imperfect

Wadi Marine Logistics is a fictional KSA shipping and warehousing operation. Some of its controls pass, some fail, one is evidenced only by a stale run, one carries an approved exception, and most have no evidence at all. A demo where everything is green would not tell you whether the scoring works — it would only tell you the dashboard renders.

Several steps below state what you should NOT see. Those are the ones worth doing carefully: a control that silently passes when it should fail is the failure mode that matters in a compliance tool.

1 Install integrity

Do	Expect
Open the NeoGRC Engine workspace	15 frameworks, 702 controls, 1,121 crosswalk edges, 9 connectors, 38 fetchers, 5 evidence sets
Open NeoGRC Framework, sort by Canonical	Exactly one canonical framework, NCC. Two would make the crosswalk pivot ambiguous and everything downstream unreliable
Open NeoGRC Control, filter framework = NCA-ECC-2	193 controls, 90 flagged Is Subcontrol, Domain and Subdomain populated
Check 2-8-1 and 2-7-1 specifically	2-8-1 under Cryptography, 2-7-1 under Data and Information Protection. These two were transposed in v0.1.0; this confirms the fix
Run bench migrate a second time	Counts unchanged. Duplicates would mean a seeder uniqueness key is wrong

2 The finding contract

This is the gate everything else depends on, so test it before anything else.

2.1 A valid batch is accepted

```
curl -X POST https://testsite/api/method/neogrc.api.ingest_findings \
-H "Authorization: token <key>:<secret>" \
-H "Content-Type: application/json" \
--data @apps/neogrc/neogrc/demo/fixtures/valid_findings.json
```

Expect 8 findings created. Run the identical command again and expect 8 findings updated, not 16 created. Ingestion is idempotent on run_id, source, resource_id and resource_type.

2.2 Dry run writes nothing

Add "dry_run": 1 to the payload and post it with a changed run_id. Expect a validation report and no new records.

2.3 An invalid batch is rejected whole

```
curl -X POST https://testsite/api/method/neogrc.api.ingest_findings \
-H "Authorization: token <key>:<secret>" \
-H "Content-Type: application/json" \
--data @apps/neogrc/neogrc/demo/fixtures/invalid_findings.json
```

Expect rejection with eight indexed errors and zero records written. Each document breaks exactly one rule:

Index	Expected error
0	fail without a message
1	fail without a severity
2	inconclusive without a message
3	status 'green' is not in the enum
4	no evaluations
5	schema major version 2 unsupported
6	negative effort_hours
7	unparseable collected_at

The critical assertion is that nothing was written

Document 0 is invalid, but documents 1 to 7 would each have been rejected individually too. If any records appear, whole-batch validation is broken — and a half-ingested run will later report its missing half as uncovered, with nobody noticing.

2.4 Permission guard

Repeat 2.1 as a user holding only NeoGRC Auditor. Expect `PermissionError`. Auditors read; they do not write findings.

3 Rollups and severity

Open finding for	Expect
wadi-prod-manifests	Rollup fail, worst severity high. Two failing evaluations — CRY-01 high, DAT-01 medium — and the worse wins
wadi-org-trail	Rollup inconclusive, not pass. LOG-01 passed but LOG-02 returned AccessDenied. Inconclusive outranks pass: the tool tried and could not determine, which is not the same as fine
arn:aws:kms:...key/abcd	CRY-04 is not_applicable with a message, and does not drag the rollup down
wadi-prod-invoices	Rollup pass, worst severity blank or info. A passing evaluation carrying a high severity must NOT inflate the finding — severity describes impact if failing, not current state

4 Crosswalk

Do	Expect
Open NCC::CRY-01, click Show Crosswalk	Mappings into several frameworks, each row marked whether it carries coverage
Open NCC::GOV-01, click Show Crosswalk	A long list, mostly 'related'. These are the family-level derivations into NCA ECC-2 and NIST CSF 2.0 — 910 of the 1,121 shipped edges
Click Conflicting Requirements on a control mapped into three or more frameworks	Rows where severity or automation posture disagrees, with the binding (stricter) obligation named
Change Canonical Framework in Settings, re-run Show Crosswalk	Different results, no error. The pivot is configurable by design. Change it back to NCC before continuing

Related edges are shown because they are a useful starting point for a consultant, and excluded from scoring because nobody has checked them at control level yet.

5 Gap assessment

This is where the scoring philosophy becomes visible, so it is the most important section of the tour.

5.1 Single framework

Create a NeoGRC Gap Assessment titled "Demo — NCC baseline", As Of now, scope framework NCC, and click Run Assessment.

- Coverage well under 20%. Nine findings cannot evidence 62 canonical controls. High coverage here would mean evidence is being counted for controls it never touched.
- Compliance noticeably higher than coverage. Of the controls actually assessed, most pass.
- Controls Not Covered is the largest bucket.

The key check is that these two numbers are reported separately and neither is presented as the headline alone. A blended figure would let this dataset look respectable when almost nothing was tested.

5.2 Worst-wins within a control

Find CRY-01 in the results table. Expect fail. Three resources reported CRY-01 — wadi-prod-manifests failed, wadi-prod-invoices and wadi-erp-prod passed. Two out of three passing does not pass the control, because the failing bucket is the one that appears in the incident report.

5.3 Staleness

Find NET-02 and CHG-01. Expect both reported as stale, not as pass: their only evidence is the k8s-inspector batch from nine days ago, and that connector's TTL is 24 hours.

Create a second assessment with Include Stale Findings ticked. Expect both to score as pass and coverage to rise slightly. Both behaviours are correct; the tick makes the choice explicit rather than silent.

5.4 Multi-framework

Scope an assessment to NCC, NCA-ECC-2 and ISO-27001-2022. Expect coverage to drop sharply — ECC-2 alone contributes 193 controls, almost all reached only by related edges that do not carry coverage.

Low ECC coverage is the correct result

Those ECC mappings are family-level derivations. Until a consultant narrows them to control level and marks them equivalent, they must not answer a regulator's control. This is the tool being honest, not the tool being broken — and it is worth understanding before a client sees the number.

5.5 Submission protects evidence

Submit the first assessment, then check NeoGRC Evidence Artifact. Artifacts behind a submitted assessment are exempt from the retention purge. Submitting is what makes evidence permanent.

6 Declarative query fetchers

Open NeoGRC Evidence Set, select ES-ERP-QUERY, and click Run Now. Expect a run touching 7 enabled fetchers; 2 of the 9 ship disabled because their correct filters depend on site conventions, as their Instructions explain.

Fetcher	Expect on the demo dataset
EVD-Q-POLICY-REVIEW	fail — DEMO-POL-002 is 435 days past review
EVD-Q-EXCEPTION-EXPIRY	fail — DEMO-EXC-002 expired 45 days ago and is still approved
EVD-Q-VENDOR-DPA	fail — Northline Payroll processes personal data with no DPA
EVD-Q-RISK-REVIEW	fail — DEMO-RSK-004 is past its review date
EVD-Q-STALE-SESSIONS	likely fail — the three demo users are dormant by design
EVD-Q-API-KEYS	depends on your site

Open a failing finding from one of these. Expect one resource per failing row, named. "Four vendors" is a status; naming the four is a task list.

6.1 Save-time validation

Change Filters to	Expect
<code>{"nonexistent_field": 1}</code>	Rejection at save, naming the field and the DocType — not at run time. A query that fails at 2am inside a scheduled run surfaces as an unexplained collection fault
<code>{"api_secret": ["is", "set"]}</code>	Refusal. Credential-shaped fields cannot be recorded as evidence: artifacts are hashed, attached and retained, and a secret must not become a permanent audit record
<code>{"enabled": 1,}</code>	Rejection naming the JSON parse error

6.2 Conditions

Change EVD-Q-POLICY-REVIEW's condition to COUNT_LTE_THRESHOLD with threshold 5 and re-run. Expect a pass: one overdue policy is within a tolerance of five.

7 Collection, preflight and exit codes

Run ES-ERP-BASELINE. Expect 11 fetchers, artifacts with SHA-256 hashes attached to the run, and findings emitted — with no credentials and no outbound network. Open any artifact and confirm the hash is populated and the file attached.

Create a fetcher with no validation rules and run it. Expect inconclusive, never pass. Collecting a file is not the same as demonstrating a control.

Do	Expect
Enable aws-inspector with no Script Root, click Preflight Check	Exit code 5 and one clear message — not eleven separate fetcher failures thirty seconds apart
Set Script Root to an empty directory, run one fetcher	Exit 5, script not found, and no findings emitted. A failed run must never emit a pass
Set a fetcher handler to ../../etc/passwd	Refusal. Also try an absolute path and a symlink pointing outside the root

Disable aws-inspector again before continuing.

8 Programme records

8.1 Risk scoring

Open DEMO-RSK-001. Expect inherent $4 \times 5 = 20$ banded Critical, residual $2 \times 5 = 10$ banded Medium. Bands recompute on save.

Open DEMO-RSK-002 (residual $4 \times 4 = 16$, High) and change Treatment to accept without linking an exception. Expect this to be blocked. Undo the change.

8.2 Exception segregation of duties

DEMO-EXC-003 is in requested state, raised by Sara. As Sara, try to approve it. Expect refusal.

This one is deliberately not configurable

An exception register where the requester signs their own approval documents nothing, and it is the first thing a competent auditor tests. Approving as Noor should succeed. Creating an exception with no expiry date should also be blocked — an exception without an end date is a permanent policy change wearing a temporary label.

8.3 Vendor PDPL gate

Open DEMO-VEN-002 (Northline Payroll), confirm Processes Personal Data is ticked and DPA Reference is empty, and save. Expect a warning or block: under PDPL Article 20 a processor without a contract is the controller's breach, not the processor's. Also check that critical tier carries a shorter review cadence than low tier.

8.4 Policy acknowledgment

Open DEMO-POL-003, currently draft, and change status to approved. Expect a queued job issuing one NeoGRC Policy Acknowledgment row per active Employee, or per enabled desk user if ERPNext is not installed.

As any user, try to mark another person's row acknowledged. Expect refusal — an acknowledgment register signed off in a bulk edit is evidence of nothing.

Bump the policy version to 0.4 and re-approve. Expect a fresh round of rows against the new version: sign-off on v0.3 does not carry forward.

9 Reports, jobs and settings

9.1 Reports

Report	Expect
Control Coverage Matrix	Which of the 62 NCC controls a fetcher can evidence, and which fetcher. Most rows blank — that is the honest picture
Findings by Control	NET-01 at the top: critical, 0.0.0.0/0 on port 22
Evidence Freshness	k8s-inspector shown stale against its TTL; erpNext-internal current
Multi Framework Optimisation	CRY-01 ranked high — one hour, auto-fixable, reaching several frameworks. Confirm a control reaching six frameworks outranks one reaching a single framework at the same cost

9.2 Scheduled jobs

```
bench --site testsite execute neogrc.setup.scheduler.expire_exceptions
bench --site testsite execute neogrc.setup.scheduler.flag_overdue_reviews
bench --site testsite execute neogrc.setup.scheduler.snapshot_metrics
bench --site testsite execute neogrc.setup.scheduler.purge_expired_artifacts
```

Expect DEMO-EXC-002 to move to expired; notifications for DEMO-POL-002, DEMO-RSK-004 and the overdue vendors; a new metric row on top of the twelve weeks the demo seeds; and artifacts behind the submitted assessment surviving the purge.

Run ES-ERP-QUERY twice in quick succession. Expect the second to be skipped while the first is in flight — a slow collection must not stack.

9.3 Residency and redaction

Confirm Residency Mode is On-Premise Only. Set AI Endpoint to a hosted provider URL and save: expect refusal. Set it to http://localhost:11434: expect acceptance. This is enforced at validation rather than left to operator discipline.

Post a finding whose resource attributes contain a key named password or token, then inspect the stored record rather than the response. Expect the value stripped on write.

9.4 Role separation

Role	Can	Cannot
NeoGRC Auditor (Khalid)	Read controls, findings, evidence, artifacts, assessments	Create or edit anything; ingest findings
NeoGRC Engineer (Sara)	Build connectors and fetchers, run collection and assessments	Delete audit records; approve her own exception

Role	Can	Cannot
NeoGRC Manager (Noor)	Everything, including delete and exception approval	Approve an exception he raised himself

The demo users ship disabled. Enable one and set a password to test a role, then disable it again.

10 Coexistence and teardown

10.1 Installing alongside your other GRC apps

```
bench --site testsite install-app alphax_grc
bench --site testsite migrate
```

Expect a clean migrate. Every NeoGRC DocType is prefixed NeoGRC, and the roles are NeoGRC Manager, Engineer and Auditor.

Before the rename these collided on GRC Control, GRC Framework, GRC Policy, GRC Vendor, GRC Exception, GRC Risk, GRC Manager and GRC Auditor. DocType and Role names are globally unique per site, so installing both apps would have broken migrate or, worse, left one app silently inheriting the other's schema.

10.2 Teardown

```
bench --site testsite execute neogrc.demo.dataset.purge
# to remove the demo users as well:
bench --site testsite execute neogrc.demo.dataset.purge \
  --kwargs '{"delete_users': 1}"
```

Expect demo records removed and seeded frameworks, controls, crosswalks, connectors and fetchers untouched. Re-check the section 1 counts; they should be identical.

11 Quick reference — what should fail

If you only have ten minutes, test these. Each is a case where a silent pass would be worse than an obvious crash.

#	Case	Expected	§
1	Invalid batch posted	Whole batch rejected, nothing written	2.3
2	Fetcher with no validation rules	Inconclusive, never pass	7
3	Failed collection run	No findings emitted	7
4	One failing resource among many	Control fails	5.2
5	Evidence past connector TTL	Stale, not pass	5.3
6	Requester approves own exception	Blocked	8.2
7	Signing someone else's acknowledgment	Blocked	8.4
8	Query filter naming a credential field	Refused at save	6.1
9	Handler path escaping the script root	Refused	7
10	Coverage and compliance	Reported separately, never blended	5.1

Neotec Integrated Solutions · Riyadh, Kingdom of Saudi Arabia · support@neotec.ai

NeoGRC v0.2.0 — Test Tour — 12 August 2026